

Background:

This checklist was developed to ensure that the acquisition of IT resources complies with Federal and DOC information security policy requirements and to provide a means to document compliance.

To assist in completing this form, a compilation of [Frequently Asked Questions \(FAQ\)](#) is available.

	System(s): <i>[Provide full name of system(s) and any corresponding acronym(s)]</i>	Date:
	Procurement Description: <i>[Provide 1-2 sentences on what the IT acquisition is for]</i>	
1.a.	Does this acquisition involve a hardware purchase? If the answer is No, proceed to question 1.b. If the answer is Yes, include appropriate clauses into the solicitation and contract to ensure this acquisition meets the following: • DOC Enterprise Cybersecurity Policy (ECP) Program requirements • Personal identity verification DOC Enterprise Cybersecurity Policy (ECP) Program requirements in accordance with FAR 4.1302, FIPS PUB 201-3, and Homeland Security Presidential Directive (HSPD-12). • FAR part 11.002(g) requirements which state that <i>unless the agency Chief Information Officer waives the requirement, when acquiring information technology using Internet Protocol, the requirements documents must include reference to the appropriate technical capabilities defined in the USGv6 Profile (NIST Special Publication (SP) 500-267) and the corresponding declarations of conformance defined in the USGv6 Test Program.</i> To meet this requirement each DOC acquisition of IP protocol technology must express requirements for IPv6 capabilities in terms of the USGv6 Profile (i.e., using the USGv6 Capabilities Check List) and vendors must be required to document their product's support of the requested capabilities through the USGv6 test program, using the USGv6 Suppliers Declaration of Conformity (USGv6 Profile Supplier's Declaration of Conformity NIST). Proceed to question 1.b.	Yes ☐ No ☐
1.b.	Does this acquisition involve a software purchase? If the answer is No, proceed to question 1.c. If the answer is Yes, include appropriate clauses into the solicitation and contract to ensure this acquisition meets the following: • DOC Enterprise Cybersecurity Policy (ECP) Program requirements • Personal identity verification DOC Enterprise Cybersecurity Policy (ECP) Program requirements in accordance with FAR 4.1302, FIPS PUB 201-3, and Homeland Security Presidential Directive (HSPD-12). • FAR part 11.002(g) requirements which state that <i>unless the agency Chief Information Officer waives the requirement, when acquiring information technology using Internet Protocol, the requirements documents must include reference to the appropriate technical capabilities defined in the USGv6 Profile (NIST Special Publication (SP) 500-267) and the corresponding declarations of conformance defined in the USGv6 Test Program.</i> To meet this requirement each DOC acquisition of IP protocol technology must express requirements for IPv6 capabilities in terms of the USGv6 Profile (i.e., using the USGv6 Capabilities Check List) and vendors must be required to document their product's support of the requested capabilities through the USGv6 test program, using the USGv6 Suppliers Declaration of Conformity (USGv6 Profile Supplier's Declaration of Conformity NIST). Proceed to question 1.b.1. and 1.b.2.	Yes ☐ No ☐

1.b.1.	If the answer to 1.b. is Yes, do any of the exceptions below apply to the entirety of the software associated with the acquisition? (select ONLY one) (i) Software with a release date or a major version change on or before September 14, 2022. (ii) Software that is not used in a Federal information system. (iii) Certain Government-developed software as identified in the requirements documents. (iv) Open source software that is freely and directly obtained by a Federal agency. (v) Software that is freely obtained and publicly available. (vi) None of the above If no exception applies (i.e., None of the above), then Secure Software Development Attestation requirements are applicable and a Secure Software Development Attestation Form, extension, or waiver is required prior to award. See Procedures for the Collection of Secure Software Development Attestations for instructions. Proceed to question 1.b.2.	☐ (i) ☐ (ii) ☐ (iii) ☐ (iv) ☐ (v) ☐ (vi)
1.b.2.	Is an attestation available (if yes, identify source or select None)? See Procedures for the Collection of Secure Software Development Attestations for instructions. Proceed to question 1.c.	☐ CIA ☐ Publicly ☐ Other ☐ None
1.c.	Does this acquisition involve collection/storage/processing of data on behalf of the government? If the answer is No, proceed to question 2. If the answer is Yes, include appropriate clauses into the solicitation and contract to ensure this acquisition meets the following: • DOC Enterprise Cybersecurity Policy (ECP) Program requirements • Personal identity verification DOC Enterprise Cybersecurity Policy (ECP) Program requirements in accordance with FAR 4.1302, FIPS PUB 201-3, and Homeland Security Presidential Directive (HSPD-12). • FAR part 11.002(g) requirements which state that unless the agency Chief Information Officer waives the requirement, when acquiring information technology using Internet Protocol, the requirements documents must include reference to the appropriate technical capabilities defined in the USGv6 Profile (NIST Special Publication (SP) 500-267) and the corresponding declarations of conformance defined in the USGv6 Test Program. To meet this requirement each DOC acquisition of IP protocol technology must express requirements for IPv6 capabilities in terms of the USGv6 Profile (i.e., using the USGV6 Capabilities Check List) and vendors must be required to document their product's support of the requested capabilities through the USGv6 test program, using the USGv6 Suppliers Declaration of Conformity (USGv6 Profile Supplier's Declaration of Conformity NIST). Proceed to question 2.	Yes ☐ No ☐
2	Will any personnel involved in this acquisition perform a function/role that requires access to a system(s) that processes non-public or sensitive NIST data? <i>For example, requiring a NIST e-mail account, system administrator access to a NIST system, vendor installation/maintenance, or contractor personnel operating system(s) that process NIST data or NIST entrusted personally identifiable information (PII) being transferred to, shared with, and/or accessed by a contractor.</i>	Yes ☐ No ☐

If the answer is No, proceed to question 3.

If the answer is Yes, Contracting Officials should work with the COR to perform the following and review and include appropriate clauses into the solicitation and contract:

- Determine and document contract risk using the [Commerce Acquisition Manual 1337.70](#). Insert the appropriate clauses into the contract based on risk level. Select from the Security Processing Requirements found at: <https://www.acquisition.gov/car/part-1352-solicitation-provisions-and-contract-clauses>
- Determine and document appropriate FISMA requirements to be met in the contract, and assist in the coordination with DOC Office of Security (OSY) for personnel screenings, see Chapter 11 Investigative Processing, of the Manual of Security Policies and Procedures, and the Office of Cybersecurity and IT Risk Management (OCRM) involving [ECP Program](#) requirements for a Security and Privacy Assessment & Authorization (A&A).
- Take appropriate action, in consultation with the COR, OSY, and NIST Office of General Counsel, regarding the personnel screening forms.
- Determine the appropriateness of allowing interim access to NIST IT systems pending favorable completion of a pre-employment check.
- Incorporate CAR [1352.239-72 Security Requirements for Information Technology Resources](#) into the solicitation and contract to ensure that the requirements, such as annual IT security awareness training, are enforceable on contract personnel.
- Take appropriate action, in consultation with your Privacy Officer, to ensure that the services, systems, and/or products being procured comply with existing privacy laws and policies regarding protection, maintenance, dissemination and disclosure of information.
- [FAR Subpart 4.19](#)— Basic Safeguarding of Covered Contractor Information Systems
 - [FAR Clause 52.204-21](#)
- [FAR Subpart 24.1](#)—Protection of Individual Privacy
 - [FAR Clause 52.224-1](#) “Privacy Act Notification”
 - [FAR Clause 52.224-2](#) “Privacy Act”
- [FAR 39.101](#)—Acquisition of Information Technology—General—Policy
- [FAR 39.105](#)—Acquisition of Information Technology—General—Privacy
- [FAR 39.106](#)— Acquisition of Information Technology—General—Contract Clause
 - [FAR Clause 52.239-1](#) “Privacy or Security Safeguards”
- [FAR Subpart 27.4](#)--Rights in Data and Copyrights

Proceed to question 3.

3	Will this acquisition involve Government property located at an off-site contractor-controlled facility that will be used for transmitting, processing, and storing NIST data and/or NIST data collected, transmitted, processed, or stored at an off-site contractor-controlled facility? If the answer is No, proceed to question 4. If the answer is Yes, include CAR 1352.239-72, Security Requirements for Information Technology Resources, into the solicitation and contract. Initiate the appropriate A&A of the system(s) involved and include A&A clauses to ensure this acquisition meets ECP Program security requirements for transmitting, processing, and storing data; and review and include appropriate clauses into the solicitation and contract as identified below: • FAR Subpart 4.19— Basic Safeguarding of Covered Contractor Information Systems ◦ FAR Clause 52.204-21 • FAR Subpart 24.1—Protection of Individual Privacy ◦ FAR Clause 52.224-1 “Privacy Act Notification” ◦ FAR Clause 52.224-2 “Privacy Act” • FAR 39.101—Acquisition of Information Technology—General—Policy • FAR 39.105—Acquisition of Information Technology—General—Privacy • FAR 39.106—Acquisition of Information Technology—General—Contract Clause ◦ FAR Clause 52.239-1 “Privacy or Security Safeguards” • FAR Subpart 27.4--Rights in Data and Copyrights Proceed to question 4.	Yes ☐ No ☐
4	Will this acquisition involve a Service Level Agreement (SLA)? <i>For example, contractor maintenance on NIST system hardware or software, administration of Software as a Service (SaaS), i.e., Cloud Computing, or External Data Storage or Contingency Emergency Back-up facility.</i> If the answer is No, proceed to question 5. If the answer is Yes, initiate appropriate A&A of the system(s) involved and include clauses to ensure this acquisition meets ECP Program security requirements for transmitting, processing, and storing data. 1.1), Secure Software Development Framework (SSDF) Recommendations for Mitigating the Risk of Software Vulnerabilities). Ensure that data portability, data breach notification, and data disposal are considered in the contract. Insert clauses from Commerce Acquisition Regulation 1337.110-70 IT Service Contracts, • High or Moderate Risk Contracts -- 48 CFR Ch. 13 1352.237-70; • Low Risk Contracts -- 48 CFR Ch. 13 1352.237.71; • National Security Contracts -- 48 CFR Ch. 13 1352.237.72; and • Foreign National Visitor and Guest Access to Departmental Resources - 1352.237-73 (for all DOC solicitations and contracts for services where foreign national access to any DOC facility or DOC IT system is required). into the contract. Also, ensure FAR part 11.002(g) requirements cited in question 1 of this checklist are followed. Security Authority to Operate Requirements 4.A: Is the Service Level Agreement in regards to a FedRAMP Authorized service? If the answer to 4.A is No, stop and work with your Operating Unit IT Security Officer to identify if a FedRAMP Authorized Solution is available, and/or plan for NIST assessment and authorization (A&A). If the answer to 4.A is Yes, or if Contractor has yet to be identified, next question.	Yes ☐ No ☐ Yes ☐ No ☐

	4.B: Does an Authority to Operate (ATO) signed letter exist for the contractor SLA? If the answer to 4B is No, Stop and work with your Operating Unit IT Security Officer. If the answer to 4B is Yes, next question. 4.C: Has the Cost of an ATO been considered in this acquisition? If the answer to 4C is No, stop and work with your Operating Unit IT Security Officer for a Cost Estimate. If the answer to 4C is Yes, next question. 4.D: Has the timeline for an ATO been considered before acquisition? If the answer to 4D is No, stop and work with your Operating Unit IT Security Officer for an ATO Timeline. If the answer to 4D is Yes, proceed to question 5.	Yes ☐ No ☐ Yes ☐ No ☐ Yes ☐ No ☐
5	Supply Chain Risk Requirements The acquisition may be subject to supply chain risk considerations¹ within contract language and/or a Supply Chain Risk Assessment² based on the below criteria. Supply Chain Risk Assessment (SCRA) Applicability: 5.A: Is this an acquisition of a new high-impact or moderate-impact information system³ using appropriated funds?⁴ 5.B: Is this an acquisition (hardware, software, services) for a National Security System (NSS)?⁵ If the answers to 5A or 5B are Yes, a SCRA is required. <i>Please refer to Procurement Memorandum-2015-08 for procedures.</i> Supply Chain Risk Considerations Applicability: 5.C: Is this an acquisition for a system, system service, system component, and/or software product identified as supporting a Mission Essential function (MEF) or a Primary Mission Essential Function (PMEF)? 5.D: Is this an acquisition for a system, system service, system component, and/or software product supporting a High Value Asset (HVA)?⁶ If the answer to 5C or 5D is Yes, <i>then Supply Chain Risk Considerations are applicable. Please refer to Procurement Memorandum 2023-12 for procedures.</i> In addition to criteria 5A – 5D above, Operating Unit management may also require supply chain risk considerations and/or a SCRA for an acquisition at their discretion. Operating Units may contact their ITSO with questions on supply chain risk considerations and/or SCRA requirements.	Yes ☐ No ☐ Yes ☐ No ☐ Yes ☐ No ☐ Yes ☐ No ☐

6	Artificial Intelligence (AI) Consistent with the <i>AI in Government Act of 2020</i>, the <i>Advancing American AI Act</i>, and <i>Executive Order 14110 on the Safe, Secure, and Trustworthy Development and Use of Artificial Intelligence</i>, agencies must manage risks from the use of AI in the Federal Government, particularly those affecting the rights and safety of the public. The acquisition, deployment, and use of AI technology is subject to the <i>U.S. Department of Commerce Technology Insertion (TI) Policy</i>, and any unauthorized or unsafe use of AI may result in the system being shut down until the violations have been remediated and the system is reauthorized. 6.A: Does this acquisition contain AI? You must have approval from the NIST CIO. If you do not have documented approval from the NIST CIO, review the guidance at https://inet.nist.gov/oism/path-forward-genai-review-approval-nist/generative-ai-gen-ai-guidance and submit the use case for approval, if applicable. Documented approval must accompany this Checklist (see question 7). Approval must be received before any acquisition. 6.B: Has this acquisition been reviewed by the organization's chief architect or enterprise architecture for use of AI? Answer YES when documented approval is obtained by the NIST CIO (which includes review for enterprise architecture). See instruction for 6.A. 6.C: Does this acquisition contain GenAI? You must have approval from the NIST CIO. If you do not have documented approval from the NIST CIO, review the guidance at https://inet.nist.gov/oism/path-forward-genai-review-approval-nist/generative-ai-gen-ai-guidance and submit the use case for approval, if applicable. Documented approval must accompany this Checklist (see question 7). Approval must be received before any acquisition.	Yes ☐ No ☐ Yes ☐ No ☐ Yes ☐ No ☐
7	Do you have any supplemental information to add to this checklist? If the answer is No, proceed to <i>Signatures</i> section below to obtain signatures. If the answer is Yes, please attach appropriate supplemental information (i.e., project org chart, previous acquisition checklist) to this checklist and proceed to <i>Signatures</i> section below to obtain signatures.	Yes ☐ No ☐

¹ Please refer to Procurement Memorandum-2023-12 for supply chain considerations procedures.

² Please refer to Procurement Memorandum 2015-08 for supply chain risk assessment requirements.

³ A new high-impact or moderate-impact information system is defined as: acquisition of a new information system that is designated as [FIPS 199](#) moderate-impact or high-impact.

⁴ Systems purchased using appropriated funds are defined in accordance with Section 515 of the Consolidated and Further Continuing Appropriations Act, 2015, Public Law 113-235 and its successor provisions in subsequent appropriations acts (and as extended in continuing resolutions).

⁵ National Security System is defined in [FIPS 200](#). The acquisition may include software, firmware, microprocessors, integrated circuitry, printed circuit boards, or any active or passive microcircuit components.

⁶ High Value Assets (HVA) are designated by the agency Senior Accountable Official for Risk Management (SAORM) based on the criteria set in [OMB M-19-03](#).

Signatures:

By signing this checklist, the Information System Security Officer, Procurement COR, Chief Information Security Officer, and Contracting Officer/GPC Approving Official are representing that Operating Unit information security management oversight and appropriate due diligence were considered for this acquisition process.

Cognizant Office of Chief Information Officer Representative (OCIO): *(delegated to Requestor's OU ITSO if SCRA)*

Name:	Phone:
Signature:	
Date:	

Information System Security Officer (ISSO):

Name:	Phone:
Signature:	
Date:	

Chief Architect or Enterprise Architecture (if answer to Q.6.A, Q.6.B, or Q.6.C. is "Yes"): *(i.e., CIO or CISO)*

Name:	Phone:
Signature:	
Date:	

NIST Chief Privacy Officer (if answer to Q.1., Q.2., or Q.3. is "Yes"): *(delegated to Requestor's OU ITSO)*

Name:	Phone:
Signature:	
Date:	

Requestor or Procurement COR (if applicable):

Name:	Phone:
Signature:	
Date:	

NIST Chief Information Security Officer: *(delegated to Requestor's OU ITSO)*

Name:	Phone:
Signature:	
Date:	

Contracting Officer or GPC Approving Official:

Name:	Phone:
Signature:	
Date:	